SKITII PRODUCT ADMIN

10-Day Task List

User management, roles and module permissions, and a permission-aware sidebar — Skitii Backend + Admin Panel.

VERSION
1.0

DATE
August 2026

AUTHOR
Swapnil Sagvekar

CUSTOMER
Internal (Skitii Product)

SCOPE
User Management, Roles & Module Permissions, Permission-aware Sidebar

Goal for Day 10

By end of Day 10:

- **Super Admin / Admin** manage internal users and roles in **Skitii Admin Panel**, APIs in **Skitii Backend**
- Each role has a **module permission matrix**: View / Create / Edit / Delete
- Sidebar shows a module only if the user has **View**
- Screens hide Create / Edit / Delete when not granted; GraphQL returns `FORBIDDEN` if called anyway
- Existing Product Admin modules (Institutions, Devices, Patients, Sessions, Music, Email, Inquiries, Blogs, Podcasts, Episodes) are gated the same way
- Hospital accounts (`INSTITUTION`, `CLINICAL_VALIDATION`) unchanged

Current state (must change)

Area	Today	After this sprint
Roles	`ADMIN`, `INSTITUTION`, `CLINICAL_VALIDATION`	Add `SUPER_ADMIN`; keep hospital roles; add **custom admin roles**
User management	Institution approve / reject / block; admin users **seeded**	Users module: list / create / edit / assign role / block
Permissions	Whole-app `ADMIN` gate	Per-module `view` · `create` · `edit` · `delete`
Sidebar	Static `menuConfig` — all items always shown	Catalog + `me` permissions; filter by `view`

Out of this 10-day plan: Trial Admin, Trial Backend, audit log UI/API (see **4-Day Audit** doc).

Overview

Days	Workstream	Duration
1	RBAC schema, module catalog, Super Admin seed	1 day
2	`me` query, permission loader, Super Admin bypass	1 day
3	User management APIs	1 day
4	Roles + permission matrix APIs	1 day
5	`PermissionsGuard` on existing Product GraphQL	1 day
6	Admin Panel — Users UI	1 day
7	Admin Panel — Roles & matrix UI	1 day
8	Permission-aware sidebar	1 day
9	Screen-level Create / Edit / Delete on existing modules	1 day
10	Polish, regression, handoff	1 day

> Skitii Backend is the **source of truth**. Admin Panel reads `me { roles, permissions }` after OTP login. Do not put the full matrix in the JWT.

Permission model

Actions (every module)

Action	Meaning in UI	Meaning on API
view	Sidebar item + list/detail	Query / GET
create	Add / New button	Create mutation
edit	Edit / Save / status change	Update / approve / reject / block
delete	Delete / archive	Delete mutation

Missing **view** → module hidden and route redirects. Missing **create** / **edit** / **delete** → control hidden **and** API `FORBIDDEN`.

Roles

Role	Who	Powers
SUPER_ADMIN	Seeded Skitii owner	All modules, all actions. Creates Admins and custom roles. Cannot be blocked or demoted by a non–Super Admin
ADMIN	Existing internal role	Powers = assigned matrix. May manage users **except** Super Admins if given Users module
Custom roles	e.g. Music Manager, Content Manager	Matrix only — no implicit full access
`INSTITUTION` / `CLINICAL_VALIDATION`	System	Unchanged; not editable in this UI

Module catalog (Product Admin)

Key	Sidebar	Backend resolvers (gate these)
`product.dashboard`	Dashboard	Counts / home queries
`product.institutions`	Institutions	`listInstitutions`, `createInstitutionByAdmin`, `approveInstitution`, `rejectInstitution`, `blockUser`, `updateInstitution`
`product.devices`	Physical Devices	Physical device list / create / update / delete
`product.patients`	Patients	Admin patient list / detail
`product.sessions`	Sessions	`listSessions`, `getSessionReadings`
`product.music_categories`	Music Categories	`createMusicCategory`, `updateMusicCategory`, `deleteMusicCategory`
`product.music_library`	Music Library	`createMusic`, `updateMusic`, `deleteMusic`
`product.email_categories`	Email Template Categories	Email category CRUD
`product.email_templates`	Email Templates	Template CRUD / duplicate / send
`product.inquiries`	Inquiries	Inquiry list / update
`product.blog_topics`	Blog Topic	`getBlogTopics` / `getBlogTopicsList` / `createBlogTopic` / `updateBlogTopic` / `deleteBlogTopic`
`product.blogs`	Blogs	`getBlogs` / `getBlog` / `createBlog` / `updateBlog` / `deleteBlog`
`product.podcast_topics`	Podcast Topic	`getPodcastTopics` / `getPodcastTopicsList` / `createPodcastTopic` / `updatePodcastTopic` / `deletePodcastTopic`
`product.podcasts`	Podcasts	`getPodcasts` / `getPodcast` / `createPodcast` / `updatePodcast` / `deletePodcast`
`product.episodes`	Episodes	`getEpisodes` / `getEpisode` / `createEpisode` / `updateEpisode` / `deleteEpisode`
`product.users`	User Management *(new)*	Internal user CRUD
`product.roles`	Roles & Permissions *(new)*	Role + matrix CRUD

`product.audit` is reserved for the **4-day Audit** sprint — do not build the page here.

Day 1 — Schema, catalog, Super Admin

Stream	Tasks	Status
Backend	Add `SUPER_ADMIN` to `Role`. Collections: `adminModules` (key, label, panel=`product`, group), `adminRoles` (name, isSystem), `adminRolePermissions` (roleId, moduleKey, view/create/edit/delete). Indexes on roleId + moduleKey. Migrate existing seeded `ADMIN` users to a default full-access admin role **or** keep `ADMIN` as a system role that still needs an explicit matrix	☐
Seed	Seed all Product module keys. Seed one Super Admin with full matrix. Existing OTP login still works	☐

Deliverable: Collections live; Super Admin can authenticate. No new UI.

Day 2 — `me`, permission loader, bypass

Stream	Tasks	Status
Backend	Permission loader: Super Admin → all true; others → union of assigned role matrices. `me` / `myPermissions` GraphQL: `{ id, email, roles, status, permissions: { [moduleKey]: { view, create, edit, delete } } }`. Load per request — **do not** embed matrix in JWT	☐
Rules	Super Admin bypasses matrix. Blocked users still rejected in `JwtStrategy`	☐

Deliverable: After OTP, Admin Panel can call `me` and receive a stable permission map.

Day 3 — User management APIs

Stream	Tasks	Status
Backend	GraphQL: list users (search, role, status, pagination); get user; create internal admin (email + roleIds); update; assign/replace roles; block/unblock with reason. Admin-created users: `APPROVED` + `isVerified` (OTP login unchanged)	☐
Rules	Requires `product.users` + matching action. Only Super Admin can create / edit / block Super Admins. Admin cannot escalate to Super Admin. Last Super Admin cannot be blocked. List may include institution users as **read-only** (no role edit)	☐

Deliverable: Users CRUD ready for Day 6 UI. Institution signup / approve flow unchanged.

Day 4 — Roles + matrix APIs

Stream	Tasks	Status
Backend	GraphQL: list / create / update / archive custom roles; get/set permission matrix (all Product modules × 4 actions). System roles (`SUPER_ADMIN` , `INSTITUTION` , `CLINICAL_VALIDATION`) view-only	☐
Validation	Unknown module keys rejected. Cannot delete a role still assigned to users (or force reassign). Saving matrix is atomic	☐

Deliverable: Changing a role's matrix changes what `me` returns on next request.

Day 5 — `PermissionsGuard` on Product GraphQL

Stream	Tasks	Status
Backend	`PermissionsGuard` + `@RequirePermission(moduleKey, action)` . Keep `@Roles` so institution users cannot hit admin resolvers. Map every existing admin resolver (see catalog table)	☐
REST	Same guard on any admin REST (music upload, etc.)	☐
Errors	Consistent `FORBIDDEN` with module + action in the message/code	☐

Deliverable: A Music Manager JWT cannot call `createInstitutionByAdmin` or `deleteMusic` if those actions are off.

Day 6 — Admin Panel: Users UI

Stream	Tasks	Status
Frontend	`/users` list: search, role filter, status, pagination. Add user (email + role). Edit, assign role(s), block/unblock with reason. Super Admin badge. Disable actions that Day 3 forbids	☐
API client	RTK/GraphQL: users + `me` . Store permissions in session after login	☐

Deliverable: Super Admin can create an internal user and they can log in via OTP.

Day 7 — Admin Panel: Roles & matrix UI

Stream	Tasks	Status
Frontend	`/roles` list. Role create/edit. Permission matrix: rows = Product modules (grouped as in sidebar), columns = View / Create / Edit / Delete. Check-all per row / column. Save. System roles read-only	☐
UX	View required before Create/Edit/Delete (checking create auto-checks view, or block save if inconsistent)	☐

Deliverable: Super Admin can create “Music Manager” (music modules only) or “Content Manager” (blogs / podcasts / episodes only) and assign it on Day 6 screen.

Day 8 — Permission-aware sidebar

Stream	Tasks	Status
Frontend	Drive `menuConfig` from module keys + `me`. Show item if `permissions[key].view`. Hide empty groups. Add **User Management** and **Roles & Permissions** (Audit left for 4-day sprint). `can(module, action)` helper	☐
Routing	Auth guard + permission guard: deep link to a hidden module → redirect to dashboard with toast	☐

Deliverable: Two users with different matrices see different sidebars. URL cheating fails.

Day 9 — Screen-level Create / Edit / Delete

Stream	Tasks	Status
Frontend	On every existing module, hide/disable Add, Edit, Delete, Approve, Reject, Block to match the matrix. Cover: Institutions, Devices, Patients, Sessions (read-only if no view), Music Categories, Music Library, Email Categories, Email Templates, Inquiries, Blog Topics, Blogs, Podcast Topics, Podcasts, Episodes	☐
Backend	Spot-check Day 5 guards still match the buttons (no UI-only security)	☐

Deliverable: Music Manager sees Music only, can create tracks, cannot touch Institutions.

Day 10 — Polish, regression, handoff

Stream	Tasks	Status
Both	Loading / empty / forbidden states. Permission refresh after role save (re-fetch `me` or next login). Seed script documented	☐
Regression	Institution OTP + tablet/product app still work. Approve / reject / block institution still works for a full-access Admin	☐

Handoff checklist

- [ ] Super Admin logs in → Users + Roles in sidebar
- [ ] Create custom role with a subset of Product modules
- [ ] Create user, assign role, OTP login — sidebar matches matrix
- [ ] Create / Edit / Delete hidden when not granted; API `FORBIDDEN` if forced
- [ ] Super Admin cannot be blocked by a regular Admin
- [ ] Last Super Admin cannot be blocked
- [ ] Institution signup / approve / product app login unchanged

Deliverable: Product Admin RBAC ready. Audit sprint can start.

Parallel Work View (Days 1–10)

```
Day:     1       2       3        4         5          6       7        8         9
10
         |
Backend  [Schema] [me+load] [Users API] [Roles API] [Guards]
Frontend                                        [Users UI] [Roles UI] [Sidebar] [Buttons] [Polish]
```

What this 10-day sprint is not

Out of scope	Where it lives
Audit log (who added/edited/deleted, history UI)	**4-Day Audit** task list
Trial Admin sidebar / Trial Backend guards	Later; Product catalog can add `trial.*` keys without rewriting users
Institution self-signup / credits	Existing Institution Management
Tablet / HNF / Product patient app roles	Unchanged
SSO	OTP + JWT stays

Checkpoint Summary

Checkpoint	Day	Expected outcome
Model ready	Day 1	Super Admin + Product module catalog
`me` ready	Day 2	Permission map after login
Users API	Day 3	Create / assign / block internal users
Roles API	Day 4	Matrix CRUD
APIs gated	Day 5	Existing admin GraphQL enforces ACL
Users UI	Day 6	Super Admin operates users in the panel
Roles UI	Day 7	Matrix editor
Sidebar	Day 8	Menu follows View
Screens gated	Day 9	Buttons follow Create / Edit / Delete
Done	Day 10	Regression + handoff

Risks for 10 Days

Risk	Mitigation
Missed resolver on Day 5	Checklist from the module catalog table; Day 10 least-privilege smoke user
JWT too large	Permissions loaded server-side; `me` is a query
Existing `ADMIN` users lose access after seed	Day 1: default matrix = full Product access for current admins
View vs Create inconsistency	Day 7 UI: create/edit/delete implies view
10 days used up before screens are gated	Days 8–9 are must-have; do not start audit until Day 10 checklist is green